Universidad Tecnológica de Tehuacán

Hernández Rodríguez Oscar Yael

8 A

ING en Área Desarrollo de Software Multiplataforma

José Miguel Carrera Pacheco

Investigación

¿Qué es autenticación y en qué se diferencia de autorización?

Es el proceso mediante el cual el sistema verifica la identidad de un usuario.Es decir, comprobar que la persona que intenta entrar realmente es quien dice ser.

Ejemplo:

1. El usuario introduce email y contraseña
2. El sistema valida esos datos en la base de datos

Es el proceso que determina qué acciones puede realizar ese usuario dentro del sistema después de haber iniciado sesión.

Ejemplo:

Usuario	Acción
user	crear publicaciones
admin	crear productos
admin	eliminar productos

¿Qué son JWT, sesiones y OAuth?

Es un token de autenticación que se usa para identificar a un usuario después de iniciar sesión.

Funciona así:

- El usuario inicia sesión
- El servidor genera un token
- El cliente guarda ese token
- En cada petición se envía el token para validar al usuario

Las sesiones funcionan de forma diferente

El usuario inicia sesión

El servidor crea una sesión en memoria o base de datos

Se guarda un ID de sesión en una cookie

El servidor revisa esa sesión en cada petición

OAuth

OAuth es un protocolo de autorización que permite iniciar sesión usando servicios externos.

Ejemplos:

Iniciar sesión con Google

Iniciar sesión con Facebook

Iniciar sesión con GitHub

¿Qué riesgos de seguridad existen en un mal diseño de autenticación?

- **Puertas abiertas a la fuerza:** No limitar los intentos de inicio de sesión permite que programas automáticos prueben miles de claves hasta acertar (**Brute Force**).
- **Mensajes "delatadores":** Decir "Ese usuario no existe" en lugar de "Datos incorrectos" le confirma al atacante qué correos sí están registrados (**Enumeración de usuarios**).
- **Sesiones "eternas":** Si la sesión no caduca al cerrar el navegador o tras un tiempo de inactividad, cualquiera que use esa misma PC después puede entrar a tu cuenta.
- **Recuperación débil:** Usar preguntas de seguridad fáciles de adivinar (como "¿A qué primaria fuiste?") es casi tan inseguro como no tener contraseña.
- **Almacenamiento descuidado:** Guardar las claves en texto plano o con cifrados antiguos. Si hackean la base de datos, el atacante se lleva todas las identidades de un solo golpe.

¿Cómo se definen roles y permisos en sistemas reales?

- **Tokens (como JWT):** El "pase" del usuario contiene sus roles codificados.
- **Middlewares**: Filtros de software que interceptan cada petición y verifican si el usuario tiene el permiso necesario antes de dejarlo pasar.
- **IAM (Identity and Access Management)**: Servicios como AWS IAM, Okta o Auth0 que centralizan toda esta lógica.